Monthly Intelligence Dispatch

May 2021

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB eliminated a fraud campaign that imitated a WHO survey. Group-IB blocked all the fraudulent domains (134 in total) within 48 hours after they were discovered.
- **Colonial Pipeline**, the largest pipeline operator in the US specializing in transporting fuel, fell victim to the DarkSide ransomware. To recover its pipeline operations, the organization paid $5 million in ransom.
- Chinese hackers attacked Rubin Design Bureau, a Russian-based defense contractor that designs submarines for the Russian Navy, **Cybereason** said.
- The **GrelosGTM** group uses Google Tag Manager to attack online shops.
- Specialists at **Cleafy** discovered TeaBot (also known as Anatsa), an Android Trojan that hijacks user credentials and SMS messages to facilitate fraudulent activities against banks in Spain, Germany, Italy, Belgium, and the Netherlands.
- The District of Columbia Central Police Department, United States, reported a hack and possible data leak after screenshots of internal files from the department's servers were published on the website of the Babuk Locker ransomware.
- Ireland's **Health Service Executive (HSE)** temporarily shut down its IT systems because of an attack involving the Conti ransomware.
- One of three operators of the WeLeakInfo portal was convicted in the Netherlands. The portal offered paid access to compromised credentials.

DarkPath Scammers

In early April 2021, the United Nations International Computing Centre (UNICC) notified Group-IB about a fake website that used the World Health Organization (WHO) brand. Users were encouraged to answer a few simple questions to earn a €200 reward on the occasion of the World Health Day, a global health awareness day celebrated every year on April 7 under the sponsorship of the WHO. However, instead of getting the promised reward, users were redirected to dating websites, paid subscription services, or fraudulent resources.

Group-IB blocked all the fraudulent resources (134 in total) within 48 hours after they were discovered. Further analysis showed that the websites were part of a larger network controlled by a scam group called **DarkPath Scammers**. The fake resources that mimicked the WHO were connected with at least 500 other scam and phishing resources impersonating more than 50 well-known international brands in the food, sportswear, e-commerce, software, automotive, and energy industries. The scammers advertise their resources through bulk email, paid ads, and social media.

Thanks to its proprietary Graph Analysis system, Group-IB analyzed dozens of SSL certificates, SSH keys, and DNS and tracked down the malicious infrastructure, unveiled the IP addresses of real servers where phishing content was stored, and detected all domains that were part of one distributed scam network.

At the moment, most of the scam websites controlled by DarkPath Scammers remain active and keep targeting millions of users around the world. Group-IB estimates that the scammers' entire network attracts around 200,000 users from the United States, India, Russia and other locations daily. Group-IB continues to monitor the scam group's activity.

DarkSide

Colonial Pipeline, the largest pipeline operator in the US specializing in transporting fuel, fell victim to the DarkSide ransomware. The attack caused problems with the supply of petrol, diesel, jet fuel, and other petrochemical products in a number of US states. The incident forced Colonial Pipeline to suspend its operations (the company transports up to 2.5 million barrels a day, which accounts for about 45% of all fuel consumed on the East Cost of the country). To recover their pipeline operations, Colonial Pipline paid $5 million in ransom.

Many ransomware programs are distributed using the ransomware-as-a-service model, which means that the same program can be used by multiple threat groups. DarkSide uses this distribution model. According to posts published by DarkSide representatives on hacker forums, their affiliate program is offered to Russian-speaking users only and its operation in Russia and other countries that are part of the Commonwealth of Independent states is prohibited; the posts are in Russian. None of the published facts directly indicate the location of the affiliate program operators and affiliates. It is possible that this is done to mislead researchers. It is clear, however, that law enforcement agencies lack experience in cooperating on an international level and neutrality in software engineering. With those things missing, arresting cybercriminals is hardly possible.

Babuk Locker

The District of Columbia Central Police Department, United States, reported a hack and possible data leak after screenshots of internal files from the department's servers were published on the website of the ransomware Babuk Locker. Babuk Locker operators said they had hacked into the law enforcers' internal network and stolen 250 GB worth of data. They posted screenshots of various folders that were stolen during the attack. As the folder names suggest, the folders contain many files related to police operations, disciplinary records, and files related to gang members and criminal gangs. The hackers warned that the law enforcers had three days to contact them and pay the ransom. Otherwise, the attackers threatened to contact the gang members featured in the documents and warn them about police informers. Bleeping Computer says the hackers' threats have not been realized, but the situation continues to develop. For instance, after the hack, the ransomware operators' negotiations with the law enforcers reached a dead end. As a result, the Babuk Locker operators started posting personal files of police officers on their website and threatened to continue doing that. The police have not commented on the situation and only say that the FBI has joined the investigation into the incident.

Conti

Ireland's Health Service Executive (HSE) temporarily shut down its IT systems because of an attack involving the Conti ransomware. Although the attack did not affect the provision of emergency medical care, it is reported that some scheduled examinations and procedures could still be postponed or canceled, as medical staff lost access to online systems, electronic patient records and other medical records. The head of the HSE Paul Read told the press that experts are currently investigating the incident and trying to assess its scale. In another interview, Reed confirmed that Conti malware operators were responsible for this attack.

Rubin Design Bureau

The security company Cybereason discovered that Chinese hackers attacked Rubin Design Bureau, a Russian-based defense contractor that designs submarines for the Russian Navy. According to Cybereason, which believes that the hackers act in the interests of the Chinese government, the attack started with a fake email that the hackers, posing as the Gidropribor concern, sent to Rubin Design Bureau's general director. The email had an attachment, which was a malicious document weaponized with a RoyalRoad payload, with the content describing a general view of an autonomous underwater vehicle. RoyalRoad used in the Rubin attack is a tool that guarantees the delivery of malicious code to the target system; it is most often used by threat groups originating from Asia. Cybereason says that the attack against Rubin Design Bureau has similarities with the activities of the Tonto and TA428 threat groups. Both have conducted attacks against Russian targets for espionage purposes. Rubin Design Bureau projects were used to build more than 85% of submarines in the Soviet Navy. Since the 1990s, Rubin has been doing civilian projects acting as the leading company in the United Shipbuilding Corporation to design facilities for offshore oil and gas field development.

Air India

Air India reported that one of their software providers experienced a data breach resulting in the personal information of 4.5 million passengers who have used the carrier for the last ten years being leaked. The leak also affected at least ten major airlines including Malaysia Airlines, Singapore Airlines, Jeju Air, Air New Zealand, Polish Airlines, Finnair, Scandinavian Airlines, Cathay Pacific, and Lufthansa. Passenger names, dates of birth, contact information, passport details, ticket information, and Star Alliance and Air India frequent flyers and their payment card details were compromised. A day after Air India disclosed the breach, a post on a darknet portal where data leaks are traded appeared from an attacker who claims that they have information about the airline's passengers.

GrelosGTM

In April 2020, Group-IB Threat Intelligence & Attribution specialists observed activity by a threat group dubbed GrelosGTM. During initial attacks in early 2020 the group used domains similar to those of well-known services, such as Google Analytics. This spring, Group-IB experts discovered that the threat actors started exploiting Google Tag Manager, a free tag management system, in attacks against online shops using JS sniffers. JS sniffers are several code strings that threat actors inject into websites to intercept data that users enter, such as bank card numbers, names, addresses, logins, passwords, etc. Threat actors usually sell data they collect to carders on specialized darknet forums. JS sniffers are currently one of the fastest growing threats to the e-commerce market globally.

TeaBot

Specialists at Cleafy discovered TeaBot (also known as Anatsa), an Android Trojan that hijacks user credentials and SMS messages to facilitate fraudulent activities against banks in Spain, Germany, Italy, Belgium, and the Netherlands. According to the specialists, the Trojan is still in its early development stages: while the first signs of its activity appeared in January, the group's attacks against financial apps have been observed only since late March 2021. The beginning of this month saw a wave of infections among banking customers in Belgium and the Netherlands. The main goal of TeaBot is to steal victims' credentials and SMS messages to enable fraud scenarios against a predefined list of banks. Once TeaBot is successfully installed on the victim's device, attackers can obtain a live stream of the device screen (on demand) and interact with it via Accessibility Services. The malware masquerades as various media and delivery services such as TeaTV, VLC Media Player, DHL, and UPS. It prompts the victim to grant it accessibility service permissions, which enables threat actors to record keystrokes, take screenshots, and show overlays on top of login screens of banking apps (to steal credentials and credit card information). In addition, TeaBot can disable Google Play Protect, intercept SMS messages, and as a result, steal Google Authenticator 2FA codes and other codes sent in text messages. The collected information is then sent to the attackers' remote server every 10 seconds.

Afterburner

MSI, a famous computer hardware producer, warned gamers about fake websites that imitated MSI's resources and downloaded malware disguised as the legitimate software Afterburner to users' computers. Afterburner is free graphics card overclocking software, which also shows detailed information about computer hardware and can even be used to manage fans. Threat actors took advantage of problems on MSI's website where gamers could download Afterburner. The company said the download link did not work for some time. Threat actors noticed that the MSI website was not working properly and set up a fake copy that looked like an alternative web resource for downloading Afterburner. Instead of the software, however, gamers had malware downloaded to their computers. Because of this, it is recommended that gamers carefully check the website they download Afterburner from. Users are strongly advised against downloading software from resources they do not feel confident in.

Arrests and sentences

WeLeakInfo

A 23-year-old Dutch man was convicted in the Netherlands. The man, who was one of three operators of WeLeakInfo, a portal that offered paid access to compromised credentials, was sentenced to two years in prison for his involvement in WeLeakInfo and will spend half of his term on probation. During the few years it existed, WeLeakInfo accumulated over 12 billion records with usernames and passwords coming from breaches of more than 10,000 databases. The service offered paid access to this information and was mostly advertised on hacker forums. Judging by a recent leak, the number of WeLeakInfo subscribers were in the thousands. In January last year, the FBI, with assistance from British, Dutch and German law enforcers, seized the WeLeakInfo.com domain. At the time, two alleged operators of the website were arrested in the Netherlands and Northern Ireland. In addition to 24 months in prison, with 12 of them on probation, the Dutch man was ordered to pay a €110,000 fine. In his statement, the convict admitted to running the service with an Irish man and a third unidentified person who remains at large. The young Dutch man joined the project in early 2016 and was mainly responsible for data processing and customer support. The Irish suspect served as the site's programmer while the third individual laundered payments made by the website's customers. The service received most of the data through donations and offered its donors free access to its databases.

Forecasts and warnings

- Critical infrastructures of most enterprises and corporations are not ready to withstand ransomware attacks. Not everyone has backups and recovering even after a ransom is paid may take months. Paying a ransom is funding cybercrime. In addition to the fact that the same victim can be attacked more than once, the number of attacks will go up, threat actors' targets will be even bigger, and ransom demands will increase.
- APT groups mostly use three scenarios for attacking their targets:
- 1) Targeted attacks. These usually involve sending out emails with malware to computers in corporate networks using social engineering techniques. Targeted attacks against networks are sometimes developed for years.
- 2) Intrusion through the external perimeter. This involves penetrating a corporate network through web services that are accessible publicly, for example, a corporate portal or email service.
- 3) Attacks against companies with air gaps. Threat actors search for air gaps to penetrate physically isolated critical network segments. In this scenario, malware may get into a network through a USB flash drive, for example.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com